



SUPPLY CHAIN ATTACKS

CHEAT SHEET

Cheat Sheet

Introduction to Supply Chains

[Supply Chains Lifecycle - Visualization](#)

What is a Supply Chain

A **Supply Chain** is the network of all the individuals, organizations, resources, activities, and technology involved in the creation and sale of a product, starting from the delivery of raw materials from the supplier to the manufacturer, and ending with the delivery of the finished product to the consumer.

Hardware Supply Chains

[Hardware Supply Chains - Visualization](#)

Hardware Supply Chains refer to the specific processes and networks used for producing physical products like electronics, machinery, and consumer goods. It includes sourcing raw materials, manufacturing components, assembly, and distribution of final hardware products.

Software Supply Chains

[Software Supply Chains - Visualization](#)

Software Supply Chains involve the stages and processes in software development, deployment, and maintenance. This includes coding, application development, integration of third-party components, and software distribution channels.

Supply Chain Attacks

Why are Supply Chain Attacks so High Impact?

Supply Chain Attacks are high impact due to their ability to exploit interconnected and often less-secure elements in a supply chain. These attacks target vulnerabilities in suppliers or third-party service providers, potentially affecting multiple entities down the chain. The extensive reach of modern supply chains means a single attack can have widespread consequences, impacting numerous organisations and customers simultaneously. These attacks can lead to significant data breaches, operational disruptions, financial losses, and damage to the reputation of all involved parties. Supply chains' complexity and integrated nature make them particularly susceptible to such attacks, amplifying their potential impact.

Lifecycle of a Supply Chain Attack

1. Target Identification

The primary goal here is to identify a viable target within the supply chain that can be exploited. This involves analysing the supply chain to find entities with valuable data or access.

Key challenges include obtaining detailed information about the supply chain and evading detection while scouting potential targets.

2. Supply Chain Exploration

The objective is to understand the supply chain's structure, relationships, and communication mechanisms. It involves mapping out the supply chain to identify key players and processes.

Challenges include the complexity and variability of supply chain networks and difficulty gaining comprehensive visibility without raising suspicions.

3. Vulnerability Discovery

The goal is to find vulnerabilities in the supply chain that can be exploited, such as weak security practices or unpatched software.

This stage is challenged by the need to thoroughly analyse multiple components and systems for vulnerabilities without access to internal resources.

4. Initial Exploitation

The primary objective is to exploit discovered vulnerabilities to gain initial access to the target's network or systems.

Challenges include bypassing security measures, avoiding detection, and gaining sufficient access to execute further actions.

5. Lateral Movement

The goal is to move through the network to access more valuable resources or data, expanding the attacker's footprint within the target environment.

This stage requires careful navigation to avoid detection while escalating privileges and accessing critical assets.

6. Target Compromise

The objective is to compromise key systems or data, achieving the primary aim of the attack, whether it be data theft, disruption, or other malicious intents.

Challenges include maintaining access without being discovered and overcoming additional security measures protecting high-value assets.

7. Data Exfiltration or Malicious Activity

The goal here is to exfiltrate sensitive data or conduct malicious activities, such as sabotage, within the compromised network.

Key challenges involve executing the intended malicious activity without triggering security alerts and successfully extracting data if that's the objective.

8. Evasion and Persistence

The final objective is to cover tracks and establish mechanisms for persistent access, allowing for future activities or continued data extraction.

This involves evading detection by security tools, removing evidence of the attack, and establishing covert channels for continued access, all while minimising the risk of discovery.

Hardware Supply Chain Attacks

Raw Material Extraction

Attacks at this stage can include sabotage of extraction equipment, cyberattacks on operational technology, or theft of raw materials.

These attacks can lead to production delays, increased costs, and compromised quality of raw materials.

Implementing strict physical and cybersecurity measures, conducting regular audits, and diversifying raw material sources are effective strategies.

Component Manufacturing

Attacks can involve implanting hardware Trojans, tampering with manufacturing processes, or stealing intellectual property.

Such attacks may result in compromised components, leading to product failures and loss of customer trust.

Regular security assessments, secure manufacturing protocols, and supply chain transparency are key to mitigating these risks.

Assembly

These attacks might include inserting malicious components or firmware during assembly or tampering with assembly lines.

Attacks at this stage can render finished products vulnerable to exploitation or cause operational failures.

Security-focused assembly processes, continuous monitoring of assembly lines, and vetting of assembly partners are crucial.

Quality Control and Testing

Attacks here can include manipulating testing software, falsifying test results, or bypassing quality checks.

This can lead to defective products reaching the market, posing safety risks and damaging the brand's reputation.

Robust quality control systems, independent audits, and strict access controls to testing processes can help mitigate these threats.

Packaging

Attacks might involve tampering with packaging to insert malicious devices or altering product labels and documentation.

Such attacks can compromise product integrity and deceive end-users, leading to potential security breaches.

Secure packaging processes, tamper-evident packaging materials, and rigorous inspection routines are effective countermeasures.

Distribution and Logistics

These include hijacking shipments, tampering with products during transit, or compromising logistics software.

Attacks can result in product theft, loss, or compromise, affecting supply chain reliability and customer trust.

Implementing tracking systems, securing transportation networks, and conducting thorough background checks on logistics partners are essential.

Retail and Sales

Attacks at this stage can involve compromising point-of-sale systems, tampering with products on shelves, or online sales fraud.

These attacks can lead to financial losses, data breaches, and erosion of customer confidence.

Enhanced cybersecurity measures for retail systems, regular inventory checks, and secure online transaction processes are key to mitigating these risks.

Insider Threats

Malicious Insiders are employees or individuals with legitimate access who intentionally harm the organisation. They may steal sensitive data, sabotage operations, or facilitate external breaches.

Negligent Insiders are individuals within the organisation who, often unintentionally, compromise security through careless actions like mishandling data or ignoring security protocols.

Infiltrators are external actors who gain legitimate access to the organisation's network, often by posing as employees or contractors, intending to conduct espionage or sabotage.

Insider threats can have a devastating impact on **Supply Chain Security**. They can lead to significant financial losses, disruption of operations, damage to the company's reputation, and erosion of customer trust. As insiders have legitimate access, their actions can be harder to detect and have far-reaching consequences across the supply chain.

Software Supply Chain Attacks

Development

Attacks during development can include inserting malicious code or backdoors into software, or compromising development tools.

These attacks can lead to compromised software products, enabling attackers to gain unauthorised access or control over systems and data.

Key strategies include implementing secure coding practices, conducting code reviews, and using trusted development tools.

Dependencies and Libraries

Attacks can involve compromising open-source libraries or dependencies used in software projects, known as dependency confusion or software composition analysis attacks.

Such attacks can result in widespread vulnerabilities across multiple applications that use the affected libraries.

Regularly scanning for vulnerable dependencies, using trusted sources for libraries, and maintaining an inventory of dependencies can mitigate these risks.

Version Control Systems

Attacks include infiltrating version control systems to alter code or access sensitive information.

Compromised version control systems can lead to unauthorised changes in software, loss of intellectual property, and potential introduction of vulnerabilities.

Securing access to version control systems, monitoring changes, and implementing strong authentication are effective measures.

Build and Integration

This can involve compromising build servers or CI/CD pipelines to insert malicious code during the build or integration process.

Attacks at this stage can result in the distribution of malicious software versions, affecting multiple users or systems.

Securing build environments, verifying third-party code, and monitoring the integrity of the build process is crucial.

Testing

Attacks here can include manipulating testing environments or tools to conceal vulnerabilities or functionality.

This can lead to software with hidden vulnerabilities being released, posing a user risk.

Using secure and isolated testing environments, verifying testing tools, and conducting thorough security testing can help mitigate these threats.

Deployment

These attacks compromise deployment mechanisms to alter or replace legitimate software with malicious versions.

Compromised deployment processes can lead to the widespread distribution of harmful software, affecting numerous users.

Securing deployment processes, verifying software integrity before deployment, and using secure distribution channels are key.

Distribution

Attacks at this stage include compromising software distribution channels, such as app stores or download sites, to distribute malicious software.

This can lead to a large-scale distribution of malware or compromised software, impacting a broad user base.

Implementing strong security measures for distribution platforms, monitoring distributed software, and ensuring secure download processes are effective mitigation strategies.